

Task 1 – Detection Logic

Ask AI:

Explain how detection logic works and create detection logic for:

Brute-force attacks
Encoded PowerShell
Suspicious DNS queries

Task 1 – Detection Logic

What is Detection Logic?

Detection logic is the set of conditions and rules used by security tools (SIEM, EDR, IDS/IPS, XDR) to identify malicious or suspicious activity. It analyzes logs, events, and system behavior to determine whether an event matches known attack patterns.

How Detection Logic Works

1. Collect Data

- Windows Event Logs
- Sysmon Logs
- Firewall Logs
- DNS Logs
- Authentication Logs
- EDR/XDR Telemetry

2. Analyze Events

- Compare events against predefined rules.
- Identify abnormal behaviors.
- Correlate related events from different sources.

3. Trigger Detection

- If rule conditions are met, generate an alert.
- Assign severity based on risk.
- Forward the alert to the SOC analyst.

1. Detection Logic – Brute-Force Attacks

Objective

Detect repeated failed login attempts that may indicate password guessing.

Data Sources

- Windows Security Event ID 4625 (Failed Login)
- Windows Event ID 4624 (Successful Login)
- Azure AD Sign-in Logs
- VPN Authentication Logs

Detection Logic

IF

More than 10 failed login attempts



```
FROM the same source IP

WITHIN 5 minutes

FOR one or multiple user accounts

THEN

Generate High Severity Alert
```

Indicators

- Multiple Event ID 4625 entries
- Same source IP
- Same username or multiple usernames
- Short time interval
- Followed by Event ID 4624 (successful login)

MITRE ATT&CK

Technique	ID
Password Guessing	T1110.001
Brute Force	T1110

Severity

High

Example

```
09:01 Failed Login

09:02 Failed Login

09:03 Failed Login

09:04 Failed Login

09:05 Failed Login

09:06 Successful Login
```



Possible credential compromise.

2. Detection Logic – Encoded PowerShell

Objective

Detect attackers attempting to hide PowerShell commands using Base64 encoding.

Data Sources

- Sysmon Event ID 1
- PowerShell Operational Logs
- EDR Process Events

Detection Logic

```
IF

Process Name = powershell.exe
```



```
AND

Command Line contains

-EncodedCommand

OR

-enc

OR

Base64 encoded strings

THEN

Generate High Severity Alert
```

Indicators

- powershell.exe
- pwsh.exe
- -EncodedCommand
- Long Base64 string
- Hidden Window
- Execution Policy Bypass

Common Suspicious Command

```
</> PowerShell

powershell.exe -EncodedCommand SQBFAFgA...
```



MITRE ATT&CK

Technique	ID
PowerShell	T1059.001
Obfuscated Files or Information	T1027

Severity

High

Detection Reason

Attackers commonly encode PowerShell commands to bypass antivirus detection and hide malicious activity.

3. Detection Logic – Suspicious DNS Queries

Objective

Detect malware communicating with command-and-control (C2) servers or using DNS tunneling.

Data Sources

- Sysmon Event ID 22
- DNS Server Logs
- Firewall Logs

- Defender XDR
- Microsoft Sentinel

Detection Logic

IF

One host performs

More than 100 DNS queries

TO an unknown domain

WITHIN 10 minutes

OR

Domain name is newly registered

OR

Very long random subdomains exist

THEN

Generate Medium/High Severity Alert

Indicators

- Random-looking domains
- Excessive DNS requests
- Long subdomains
- TXT record abuse
- Domains with poor reputation
- Frequent NXDOMAIN responses

Example

asjd82js8d.example.com

jdh728dj3.example.com

hshd8272.example.com

Possible DNS tunneling or malware beaconing.

MITRE ATT&CK

Technique	ID
Application Layer Protocol: DNS	T1071.004
Dynamic Resolution	T1568

Severity

Medium → High

Depends on:

- Query frequency
- Domain reputation
- DNS record type
- Endpoint involved

Summary Table

Threat	Detection Logic	Primary Logs	MITRE ATT&CK	Severity
Brute-Force Attack	Multiple failed logins from the same IP within a short time, optionally followed by a successful login	Windows Event ID 4625, 4624	T1110, T1110.001	High
Encoded PowerShell	Detect <code>powershell.exe</code> using <code>-EncodedCommand</code> , <code>-enc</code> , or long Base64-encoded command lines	Sysmon Event ID 1, PowerShell Logs, EDR	T1059.001, T1027	High
Suspicious DNS Queries	High-volume queries, random or newly registered domains, long subdomains, or DNS tunneling patterns	Sysmon Event ID 22, DNS Logs, Firewall Logs	T1071.004, T1568	Medium–High

SOC Analyst Recommendations

- Configure alert thresholds carefully to reduce false positives.
- Correlate authentication, process, and network telemetry instead of relying on a single event.
- Enrich alerts with threat intelligence (domain/IP reputation) before triage.
- Map detections to the MITRE ATT&CK framework for consistent investigation and reporting.
- Continuously tune detection logic based on your organization's normal activity and emerging attack techniques.

Task 2 – Detection Types

Ask AI to compare:

Signature-based detection
Rule-based detection
Behavioral detection
Threat intelligence detection
AI/ML detection

Include advantages, limitations, and SOC use cases.

Task 2 – Detection Types

Modern SOC's use multiple detection methods together because no single technique can detect every threat. Each detection type has unique strengths and weaknesses, making them suitable for different attack scenarios.

Detection Types Comparison

Detection Type	How It Works	Advantages	Limitations	Common Cases
Signature-Based Detection	Compares files, processes, or network traffic against known malware signatures or hashes.	Fast, accurate for known threats, low false positives, easy to implement.	Cannot detect new (zero-day) or modified malware, requires frequent signature updates.	Antivirus detection families.
Rule-Based Detection	Detects activity based on predefined rules or conditions written by security teams.	Highly customizable, transparent, easy to tune, effective for known attack patterns.	Requires continuous maintenance, may generate false positives if poorly configured, misses unknown techniques.	SIEM correlation rules, Web application monitoring alerts.
Behavioral Detection	Monitors user, process, and system behavior to identify anomalies or suspicious activities.	Detects unknown attacks, insider threats, fileless malware, and living-off-the-land techniques.	Higher false positives, requires baseline learning, more resource intensive.	EDR/XDR, User movement, Escalation of privilege
Threat Intelligence Detection	Compares logs against known Indicators of Compromise (IOCs) such as malicious IPs, domains, URLs, hashes, and certificates.	Quickly identifies known malicious infrastructure, easy to automate, enriches investigations.	Ineffective against new or previously unseen threats, IOC lists can become outdated quickly.	Blocking phishing, Blocking malicious communication
AI/ML Detection	Uses machine learning models to identify anomalies, predict malicious behavior, and correlate large volumes of security data.	Detects complex and previously unknown attacks, reduces analyst workload, improves large-scale correlation.	Can produce false positives, requires quality training data, decisions may be difficult to explain, computationally intensive.	Advanced anomaly detection, Automated threat hunting

1. Signature-Based Detection

Overview

Signature-based detection identifies threats by comparing files, processes, or network traffic against a database of known malicious signatures.

How It Works



Advantages

- Very fast detection
- High accuracy for known malware
- Low false-positive rate
- Easy to deploy and maintain

Limitations

- Cannot detect zero-day attacks
- Misses polymorphic or obfuscated malware
- Requires frequent signature updates

SOC Use Cases

- Antivirus scanning
 - Malware hash detection
 - IDS/IPS signature matching
 - Known ransomware detection
-

2. Rule-Based Detection

Overview

Rule-based detection relies on predefined conditions that identify suspicious events in system or network logs.

Example Rule

```
IF
  Event ID = 4625
  AND
  Failed Logins > 10
  Within 5 Minutes
THEN
  Generate Alert
```



Advantages

- Highly customizable
- Easy to understand and audit
- Effective for common attack techniques
- Supports MITRE ATT&CK mapping

Limitations

- Requires continuous tuning
- Cannot detect unknown attack techniques
- May generate false positives if thresholds are not optimized

SOC Use Cases

- SIEM correlation rules
 - Sigma rule deployment
 - Brute-force detection
 - PowerShell monitoring
 - Registry modification alerts
-

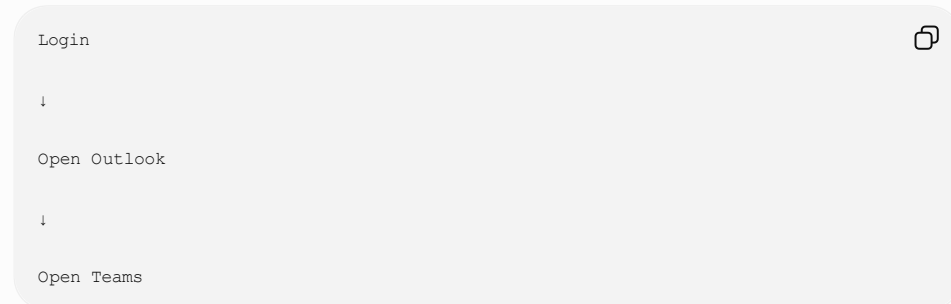
3. Behavioral Detection

Overview

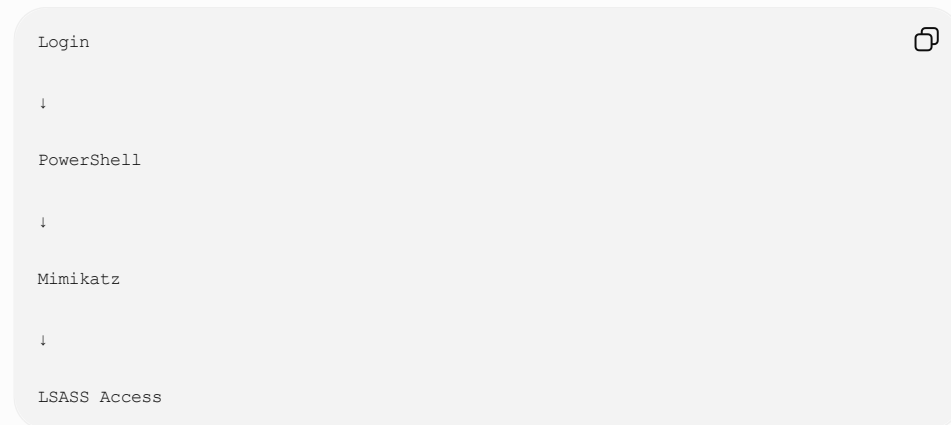
Behavioral detection identifies malicious activity by monitoring deviations from normal system, user, or process behavior rather than relying on known signatures.

Example

Normal User



Abnormal User



Behavior deviates from the baseline → Alert generated.

Advantages

- Detects unknown threats
- Effective against fileless malware
- Detects insider threats
- Identifies lateral movement and privilege escalation

Limitations

- Higher false-positive rate
- Requires baseline learning
- More computationally intensive

SOC Use Cases

- User and Entity Behavior Analytics (UEBA)
- Endpoint Detection and Response (EDR)
- Insider threat detection
- Credential theft investigations

4. Threat Intelligence Detection

Overview

Threat intelligence detection compares observed activity against known malicious Indicators of Compromise (IOCs).

Common IOCs

- Malicious IP addresses
- Domains
- URLs
- File hashes
- Certificates
- Email addresses

Example

DNS Query



↓

evil-domain.xyz

↓

Threat Intelligence Feed Match

↓

Generate Alert

Advantages

- Quickly identifies known threats
- Easy to automate
- Adds context to investigations
- Improves detection accuracy when combined with other methods

Limitations

- Misses new threats with no published IOCs
- IOC feeds require regular updates
- Attackers frequently rotate infrastructure

SOC Use Cases

- Blocking malicious IPs
- Phishing detection
- C2 communication detection
- IOC enrichment during incident response

5. AI/ML Detection

Overview

AI/ML-based detection uses machine learning algorithms to analyze large volumes of security data and identify patterns that indicate malicious activity.

Example Workflow

Millions of Events



↓

Machine Learning Model

↓

Risk Score

↓

High-Risk Events

↓

SOC Alert

Advantages

- Detects previously unseen attacks
- Finds subtle behavioral anomalies
- Automates alert prioritization
- Improves efficiency in large SOC environments

Limitations

- Requires quality training data
- May produce false positives
- Model decisions can be difficult to interpret
- Resource intensive

SOC Use Cases

- Automated SOC triage
- UEBA
- Advanced phishing detection
- Fraud detection
- Large-scale anomaly detection

Real-World Detection Examples

Attack Scenario	Best Detection Type	Reason
Known malware executable	Signature-Based	Malware signature already exists.
Multiple failed login attempts	Rule-Based	Threshold-based authentication rule is effective.
PowerShell launching from Microsoft Word	Behavioral	Unusual parent-child process relationship indicates suspicious activity.
Connection to a known malicious IP	Threat Intelligence	IOC matches a threat intelligence feed.
Previously unseen ransomware behavior	AI/ML	Behavioral patterns and anomaly detection identify the threat before a signature exists.

Comparison Summary

Feature	Signature-Based	Rule-Based	Behavioral	Threat Intelligence	AI/ML
Detects Known Threats	✓ Excellent	✓ Excellent	✓ Good	✓ Excellent	✓ Good
Detects Unknown Threats	✗ No	⚠ Limited	✓ Yes	✗ No	✓ Excellent
Low False Positives	✓ High	✓ Good (with tuning)	⚠ Moderate	✓ High	⚠ Moderate
Easy to Explain	✓ Yes	✓ Yes	⚠ Moderate	✓ Yes	✗ Often difficult
Requires Continuous Updates	✓ Signatures	✓ Rules	⚠ Baselines	✓ IOC Feeds	✓ Models & Data
Typical SOC Tools	Antivirus, IDS/IPS	SIEM, Sigma	EDR/XDR, UEBA	Threat Intelligence Platforms, SIEM	XDR, UEBA, AI-assisted SIEM

SOC Analyst Takeaways

- **Signature-based detection** is ideal for identifying known malware quickly but is ineffective against new threats.
- **Rule-based detection** provides reliable, customizable alerts for well-understood attack techniques and is the foundation of most SIEM deployments.
- **Behavioral detection** excels at identifying fileless attacks, insider threats, and other anomalous activities that evade traditional signatures.
- **Threat intelligence detection** enriches investigations by matching activity against known malicious infrastructure and IOCs.
- **AI/ML detection** enhances modern SOC operations by correlating large datasets, prioritizing alerts, and detecting sophisticated or previously unseen attacks.

Task 3 – Detection Tuning

Best Practice: A mature SOC combines all five detection types in a layered defense strategy. Signature and rule-based detection provide reliable coverage for known threats, while behavioral analysis, threat intelligence, and AI/ML improve visibility into advanced and emerging attacks, reducing overall detection gaps.

A Sigma rule detecting PowerShell is generating too many false positives.

Ask AI to:

Explain why.

Recommend tuning improvements.

Show more ▾

Task 3 – Detection Tuning

Scenario

A Security Operations Center (SOC) has deployed a **Sigma rule** that generates an alert whenever **PowerShell** (`powershell.exe` or `pwsh.exe`) is executed.

Within a few days, analysts notice hundreds of alerts every day. Investigation reveals that most alerts are triggered by legitimate administrative activities such as:

- System administrators running maintenance scripts
- Microsoft management tools
- Software installation and update processes
- Backup and monitoring solutions
- IT automation scripts
- Configuration management tools (e.g., Intune, SCCM)

Only a very small percentage of the alerts represent suspicious activity.

The SOC team wants to tune the detection to reduce false positives while continuing to detect malicious PowerShell usage.

Why is the Rule Generating Too Many False Positives?

The rule is overly broad because it alerts on **every PowerShell execution**, regardless of context.

PowerShell is a legitimate administration tool used extensively in Windows environments. Alerting on every execution creates unnecessary noise and leads to **alert fatigue**, making it easier for analysts to overlook genuine threats.

Common Causes of False Positives

- Administrators running maintenance scripts
- Scheduled tasks using PowerShell
- Microsoft Windows management operations
- Software deployment tools (e.g., SCCM, Intune)
- Backup or monitoring software
- Security products executing PowerShell
- Login or startup scripts
- Automation frameworks

Recommended Detection Tuning Improvements

1. Detect Suspicious Command-Line Arguments

Instead of alerting on all PowerShell executions, focus on arguments commonly associated with malicious activity.

Alert On

- `-EncodedCommand`
- `-enc`
- `-ExecutionPolicy Bypass`
- `-NoProfile`
- `-WindowStyle Hidden`
- `-nop`
- `-w hidden`

Example

Benign

```
<> PowerShell
powershell.exe Get-Service
```



Suspicious

PowerShell



```
powershell.exe -EncodedCommand SQBFAFgA...
```

2. Monitor Unusual Parent Processes

Legitimate PowerShell sessions are typically launched from trusted applications such as `explorer.exe` or administrative consoles.

PowerShell launched by unexpected parent processes is more suspicious.

High-Risk Parent Processes

- `winword.exe`
- `excel.exe`
- `outlook.exe`
- `acrord32.exe`
- `chrome.exe`
- `firefox.exe`
- `msedge.exe`
- `wscript.exe`
- `cscript.exe`

Example

```
WINWORD.EXE  
↓  
powershell.exe
```



This may indicate a malicious Office macro.

3. Exclude Trusted Accounts

Create an allowlist for approved administrative or service accounts that regularly execute PowerShell as part of normal operations.

Examples

- Domain Administrators
- Backup service accounts
- SCCM service accounts
- Intune management accounts
- Monitoring accounts

Regularly review the allowlist to ensure it remains accurate and does not become overly permissive.

4. Exclude Trusted Script Paths

Ignore PowerShell scripts executed from approved internal directories.

Example Allowlist

```
C:\Program Files\  
C:\Windows\  
C:\CompanyScripts\
```



Continue to alert on scripts launched from locations such as:

Downloads
Desktop
Temp
AppData
Public
Recycle Bin



5. Detect Network Activity

Increase alert priority when PowerShell initiates outbound network connections.

Examples include:

- HTTP/HTTPS requests
- DNS lookups to unknown domains
- Downloads using `Invoke-WebRequest`
- `Invoke-Expression (IEX)`
- WebClient downloads
- Connections to public IP addresses

6. Correlate with Other Security Events

Rather than relying on PowerShell execution alone, combine multiple indicators.

High-Fidelity Detection

PowerShell

+

Encoded Command

+

Network Connection

+

Registry Modification

=

High Confidence Alert



Correlating multiple suspicious events significantly reduces false positives.

7. Monitor Suspicious PowerShell Cmdlets

Increase the alert score when dangerous cmdlets are observed.

Examples include:

- `Invoke-WebRequest`
- `Invoke-Expression`
- `DownloadString`
- `Net.WebClient`
- `Add-MpPreference`

- `Set-MpPreference`
- `New-Object Net.WebClient`
- `FromBase64String`

8. Apply Severity-Based Alerting

Instead of assigning every alert the same priority, classify alerts based on risk.

Activity	Severity
Standard administrative PowerShell	Informational
Unknown user running PowerShell	Low
Encoded PowerShell command	High
Encoded PowerShell + network connection	High
PowerShell launched from Microsoft Word	High
PowerShell modifying Defender settings	Critical
PowerShell downloading and executing remote code	Critical

This allows analysts to focus on the highest-risk events first.

Example of a Tuned Detection Logic

```
IF
  Process = powershell.exe
  AND
  (
    CommandLine contains "-EncodedCommand"
    OR CommandLine contains "-ExecutionPolicy Bypass"
    OR CommandLine contains "Invoke-WebRequest"
    OR CommandLine contains "DownloadString"
  )
  AND
  ParentProcess NOT IN
  (
    explorer.exe,
    mmc.exe,
    services.exe
  )
  AND
  User NOT IN
  (
    Approved_Admin_Accounts
  )
  THEN
  Generate High Severity Alert
```



Before and After Tuning

Detection Metric	Before Tuning	After Tuning
PowerShell alerts per day	1,000	80
False positives	Very High	Low
Analyst investigation time	High	Significantly Reduced
Detection of malicious PowerShell	Moderate	High
Alert fidelity	Low	High

Best Practices for Reducing False Positives

- Use command-line analysis instead of process name alone.
- Monitor suspicious parent-child process relationships.
- Correlate PowerShell events with network, registry, authentication, and file activity.
- Maintain and regularly review allowlists for trusted accounts and script locations.
- Assign severity based on behavioral context rather than a single event.
- Continuously review alerts and tune detection logic as the environment and attacker techniques evolve.

SOC Analyst Recommendations

A well-tuned PowerShell detection should prioritize **behavior over mere execution**.

Rather than alerting every time `powershell.exe` runs, focus on indicators such as encoded commands, execution policy bypasses, suspicious parent processes, outbound network activity, and other correlated events. This approach reduces false positives, minimizes analyst fatigue, and improves the likelihood of detecting genuine attacks without sacrificing visibility.

Task 4 – Detection Engineering Exercise

Ask AI:

Create five SOC detections for:

Brute-force login
Encoded PowerShell
Registry persistence
Suspicious DNS activity
Outbound HTTPS communication

Show more ▾

Task 4 – Detection Engineering Exercise

Below are five practical SOC detections that can be implemented in a SIEM, EDR, or XDR platform. Each detection includes the detection logic, required data sources, severity, MITRE ATT&CK mapping, and false-positive considerations.

Detection 1 – Brute-Force Login

Objective

Detect repeated failed authentication attempts that may indicate a password guessing or brute-force attack.

Detection Logic



```
IF

Failed Login Events (Event ID 4625)

FROM the same Source IP

OR

Against the same User Account

More than 10 times

Within 5 minutes

THEN

Generate High Severity Alert

Increase severity if followed by a successful login (Event ID 4624).
```

Data Sources

- Windows Security Logs
- Domain Controller Logs
- VPN Authentication Logs
- Azure AD / Entra ID Sign-in Logs
- Microsoft Defender XDR Identity Events

Severity

High

Increase to **Critical** if a successful login follows repeated failures.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Credential Access	Brute Force	T1110
Credential Access	Password Guessing	T1110.001

False-Positive Considerations

Possible legitimate causes include:

- Users forgetting passwords
- Password manager synchronization issues
- VPN reconnection attempts
- Misconfigured applications repeatedly authenticating
- Service accounts with expired credentials

Recommended Tuning

- Exclude trusted scanners and monitoring systems.
- Ignore known service accounts.
- Apply thresholds per user and source IP.

- Correlate with successful logins and geolocation anomalies.

Detection 2 – Encoded PowerShell

Objective

Detect PowerShell commands that use obfuscation to hide malicious activity.

Detection Logic

```
IF
    Process = powershell.exe OR pwsh.exe
    AND
    CommandLine contains
        -EncodedCommand
    OR
        -enc
    OR
        Base64-encoded strings
    OR
        ExecutionPolicy Bypass
THEN
    Generate High Severity Alert
```



Data Sources

- Sysmon Event ID 1
- PowerShell Operational Logs
- Windows Event Logs
- Microsoft Defender XDR Process Events
- EDR Telemetry

Severity

High

Increase to **Critical** if the process also performs network activity or modifies security settings.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Execution	PowerShell	T1059.001
Defense Evasion	Obfuscated Files or Information	T1027

False-Positive Considerations

Potential legitimate activity:

- Administrative automation scripts

- Software deployment tools
- Backup scripts
- Configuration management platforms

Recommended Tuning

- Allowlist trusted administrative accounts.
- Exclude approved script directories.
- Alert only when suspicious command-line arguments or unusual parent processes are observed.
- Correlate with network connections or registry modifications.

Detection 3 – Registry Persistence

Objective

Detect attempts to establish persistence by modifying Windows Registry autorun locations.

Detection Logic

IF

Registry Key Modified

AND

Registry Path IN

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

HKLM\Software\Microsoft\Windows\CurrentVersion\Run

RunOnce

StartupApproved

THEN

Generate Medium Severity Alert

Increase severity if the value points to a suspicious executable or script.

Data Sources

- Sysmon Event ID 13 (Registry Value Set)
- Windows Security Logs
- Microsoft Defender XDR
- EDR Registry Telemetry

Severity

Medium

Increase to **High** if the registry value references PowerShell, script interpreters, or executables in user-writable locations.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Persistence	Registry Run Keys / Startup Folder	T1547.001

False-Positive Considerations

Legitimate software may create autorun entries during installation or updates.

Examples include:

- Microsoft Office
- Google Chrome
- Zoom
- OneDrive
- Enterprise endpoint management tools

Recommended Tuning

- Exclude approved software publishers.
- Alert only on newly created entries.
- Prioritize unsigned binaries or scripts.
- Correlate with recent process creation events.

Detection 4 – Suspicious DNS Activity

Objective

Detect DNS behavior that may indicate malware beaconing, DNS tunneling, or command-and-control communication.

Detection Logic

```
IF
  Host generates
    More than 100 DNS queries
    Within 10 minutes
  OR
    Queries contain
      Long random subdomains
    OR
      High number of TXT requests
    OR
      Multiple NXDOMAIN responses
  THEN
    Generate Medium/High Severity Alert
```



Data Sources

- Sysmon Event ID 22 (DNS Query)
- DNS Server Logs
- Firewall Logs
- Microsoft Defender XDR
- Microsoft Sentinel

Severity

Medium

Increase to **High** if the queried domain has a poor reputation or is associated with known malware.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Command and Control	Application Layer Protocol: DNS	T1071.004
Command and Control	Dynamic Resolution	T1568

False-Positive Considerations

Legitimate sources of high DNS activity include:

- Web browsers
- CDNs
- Cloud applications
- Software update services
- Security products

Recommended Tuning

- Allowlist trusted domains (e.g., Microsoft, Google, Cloudflare).
- Use threat intelligence to identify malicious domains.
- Focus on entropy, query frequency, and uncommon record types.
- Correlate with outbound network connections.

Detection 5 – Outbound HTTPS Communication

Objective

Detect suspicious outbound HTTPS connections that may indicate malware communication with external command-and-control servers.

Detection Logic

```
IF
  Process initiates HTTPS connection
  TO
    Unknown or low-reputation external IP or domain
  AND
    Destination is not on the corporate allowlist
  OR
    HTTPS communication occurs immediately after
    PowerShell execution
  OR
    Encoded command execution
  THEN
    Generate High Severity Alert
```



Data Sources

- Firewall Logs
- Proxy Logs
- Microsoft Defender XDR Network Events
- Sysmon Event ID 3 (Network Connection)
- EDR Network Telemetry

Severity

High

Increase to **Critical** if the connection is followed by malware execution, data exfiltration, or persistence.

MITRE ATT&CK Mapping

Tactic	Technique	ID
Command and Control	Web Protocols	T1071.001
Exfiltration	Exfiltration Over Web Service	T1567

False-Positive Considerations

Legitimate HTTPS traffic is extremely common.

Examples include:

- Web browsers
- Cloud services (Microsoft 365, Google Workspace)
- Software updates
- Backup applications
- Enterprise SaaS platforms

Recommended Tuning

- Allowlist trusted domains and business applications.
- Alert only on unknown destinations or rare destinations.
- Correlate with suspicious process activity, threat intelligence, and abnormal data transfer volumes.
- Use reputation scoring for external domains and IP addresses.

Detection Summary

Detection	Primary Data Source	Severity	MITRE ATT&CK	Common False Positives
Brute-Force Login	Windows Security Logs (4625/4624), Identity Logs	High	T1110, T1110.001	User password mistakes, expired service account credentials
Encoded PowerShell	Sysmon Event ID 1, PowerShell Logs, EDR	High	T1059.001, T1027	Administrative scripts, automation tools
Registry Persistence	Sysmon Event ID 13, EDR Registry Telemetry	Medium–High	T1547.001	Legitimate software installations and updates
Suspicious DNS Activity	Sysmon Event ID 22, DNS Logs	Medium–High	T1071.004, T1568	Browsers, cloud services, software updates

Detection	Primary Data Source	Severity	MITRE ATT&CK	Common False Positives
Outbound HTTPS Communication	Firewall, Proxy, Sysmon Event ID 3, EDR	High–Critical	T1071.001, T1567	Business web traffic, SaaS applications, software updates

Detection Engineering Best Practices

- Build detections using multiple telemetry sources rather than a single event.
- Correlate process, network, authentication, and registry events to improve confidence.
- Tune thresholds and maintain allowlists for trusted users, applications, and domains.
- Enrich alerts with threat intelligence to prioritize known malicious infrastructure.
- Map detections to the MITRE ATT&CK framework to standardize analysis and reporting.
- Continuously review detection performance and refine rules based on new attack techniques and observed MITRE ATT&CK scenarios.

Scenario

A SOC receives multiple alerts generated by newly deployed detection rules:

Ten failed Administrator logins in five minutes.
 Encoded PowerShell execution.
 Registry Run Key modification.
 Repeated DNS requests to an unknown domain.
 Outbound HTTPS connection immediately afterward.

Show more ▾

Mini Investigation Scenario – Multi-Alert Correlation

Scenario

A Security Operations Center (SOC) receives multiple alerts from newly deployed detection rules for a single endpoint:

1. Ten failed **Administrator** login attempts within five minutes.
2. **Encoded PowerShell** execution.
3. **Registry Run Key** modification.
4. Repeated **DNS requests** to an unknown domain.
5. **Outbound HTTPS connection** immediately afterward.

The goal is to determine whether these alerts are related, understand the attacker's objectives, assess the severity, and identify opportunities to improve detection coverage.

1. Correlating All Detections

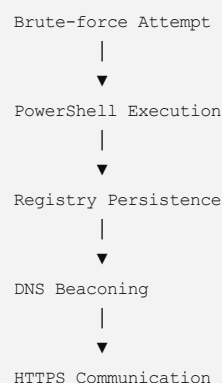
These alerts form a logical attack chain rather than isolated events. When viewed together, they strongly suggest an active compromise.

Attack Timeline

Time	Detection	Interpretation
09:10	Multiple failed Administrator logins	Possible password guessing or brute-force attempt.
09:12	Encoded PowerShell execution	Suspicious execution using obfuscation to evade detection.

Time	Detection	Interpretation
09:13	Registry Run Key modification	Persistence established to survive system reboots.
09:14	Repeated DNS requests to an unknown domain	Likely command-and-control (C2) discovery or DNS beaconing.
09:15	Outbound HTTPS connection	Encrypted communication with external infrastructure, possibly for C2 or data exfiltration.

Correlation Summary



This sequence aligns with the progression of a typical cyberattack, from initial access through command and control.

2. Why Each Rule Triggered

Detection 1 – Brute-Force Login

Trigger

- More than 10 failed Administrator login attempts occurred within five minutes.

Why It Triggered

The authentication rule exceeded the configured threshold, indicating possible password guessing.

Possible Explanation

- External attacker attempting credential compromise.
- Password spraying.
- Automated brute-force tool.

Detection 2 – Encoded PowerShell

Trigger

PowerShell was launched with an encoded command (`-EncodedCommand`).

Why It Triggered

Encoded PowerShell is frequently used to:

- Hide malicious commands.

- Evade antivirus detection.
- Bypass simple monitoring rules.

Possible Explanation

The attacker executed a payload after obtaining or attempting privileged access.

Detection 3 – Registry Run Key Modification

Trigger

A Windows Run key was modified.

Why It Triggered

The detection identified changes to autorun registry locations commonly used for persistence.

Possible Explanation

The attacker wants malicious code to execute automatically after reboot or user logon.

Detection 4 – Suspicious DNS Requests

Trigger

A high number of DNS queries targeted an unknown or suspicious domain.

Why It Triggered

The detection identified unusual DNS behavior, such as:

- Numerous requests in a short period.
- Unknown or low-reputation domain.
- Potential beaconing pattern.

Possible Explanation

The compromised host may be locating or communicating with a command-and-control server.

Detection 5 – Outbound HTTPS Connection

Trigger

An outbound HTTPS connection was established immediately after the PowerShell execution and DNS activity.

Why It Triggered

The destination was not recognized as a trusted domain and the timing correlated with previous suspicious events.

Possible Explanation

The attacker may be:

- Downloading additional malware.
 - Receiving commands.
 - Exfiltrating data over encrypted HTTPS.
-

3. Possible Attacker Objectives

Based on the sequence of events, the attacker could have several objectives.

Objective	Evidence
Gain unauthorized access	Multiple failed Administrator login attempts.
Execute malicious code	Encoded PowerShell execution.
Establish persistence	Registry Run key modification.
Communicate with C2 infrastructure	Repeated DNS queries and outbound HTTPS connection.
Download additional payloads	HTTPS connection immediately after DNS resolution.
Exfiltrate sensitive data	Encrypted outbound communication could conceal data theft.
Maintain long-term access	Persistence mechanism combined with remote communication.

4. MITRE ATT&CK Mapping

Tactic	Technique	ID
Credential Access	Brute Force	T1110
Execution	PowerShell	T1059.001
Defense Evasion	Obfuscated Files or Information	T1027
Persistence	Registry Run Keys / Startup Folder	T1547.001
Command and Control	Application Layer Protocol: DNS	T1071.004
Command and Control	Application Layer Protocol: Web Protocols	T1071.001

5. Severity Assessment

Overall Severity: Critical

Justification

This is not a single suspicious event. Multiple detections align across different phases of the attack lifecycle:

- Credential access attempt
- Potential code execution
- Persistence established
- External communications initiated

The correlated evidence significantly increases confidence that the endpoint has been compromised.

6. Immediate SOC Response

1. Isolate the affected endpoint from the network.
2. Disable or reset the targeted Administrator account if compromise is suspected.
3. Block the suspicious domain and associated IP addresses.
4. Terminate malicious PowerShell processes.
5. Remove unauthorized registry Run key entries.
6. Acquire memory and disk evidence for forensic analysis.
7. Search the environment for similar indicators of compromise (IOCs).
8. Review outbound network traffic for possible data exfiltration.
9. Rotate credentials for privileged accounts if compromise is confirmed.

7. Recommended Additional Detections

Detection	Purpose
Successful login after multiple failed attempts	Identify account compromise following brute-force attacks.
PowerShell downloading remote content (<code>Invoke-WebRequest</code> , <code>DownloadString</code>)	Detect payload retrieval.
Office application spawning PowerShell	Identify malicious macros and phishing payloads.
LSASS memory access	Detect credential dumping attempts.
Creation of scheduled tasks	Identify additional persistence mechanisms.
New local administrator account creation	Detect privilege escalation or persistence.
Windows service creation	Detect malware installed as a service.
File creation in Startup folders	Identify startup persistence.
Large outbound data transfers	Detect potential data exfiltration.
Connections to newly registered or low-reputation domains	Improve command-and-control detection.
RDP or SMB lateral movement	Detect movement to additional hosts.
Security tool tampering	Identify attempts to disable antivirus, EDR, or logging.

8. Overall Incident Assessment

The combined alerts strongly indicate a coordinated attack rather than unrelated events. The activity is consistent with a progression through the cyberattack lifecycle:

1. Attempt to obtain privileged credentials.
2. Execute obfuscated commands using PowerShell.
3. Establish persistence via registry modifications.
4. Resolve and contact external infrastructure.
5. Maintain encrypted communications with a likely command-and-control server.

This pattern warrants immediate containment and a full incident response investigation.

SOC Analyst Conclusion

The correlated detections provide **high-confidence evidence of a likely endpoint compromise**. While any individual alert could have a benign explanation, the combination of authentication anomalies, encoded PowerShell, persistence, suspicious DNS activity, and outbound HTTPS communication is characteristic of adversary behavior. The incident should be treated as **Critical**, with immediate containment, forensic collection, IOC hunting across the environment, and credential protection measures initiated. Continuous tuning of these detections and adding complementary rules—such as monitoring credential dumping, lateral movement, and defense evasion—will further strengthen the organization's detection capabilities.